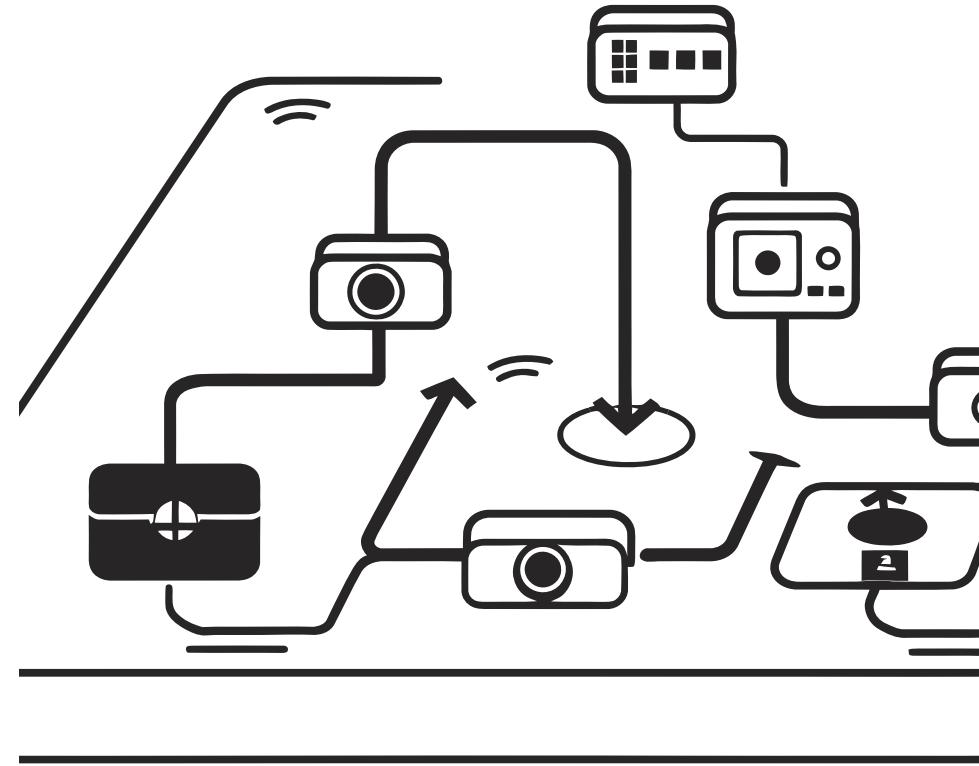


Teoria R2 — Estat, sessió i cookies

Fonaments teòrics per preparar R2M4: com HTTP gestiona l'estat, les sessions, les cookies i el context de petició.

CICLE FORMATIU · DESENVOLUPAMENT WEB



HTTP no recorda res

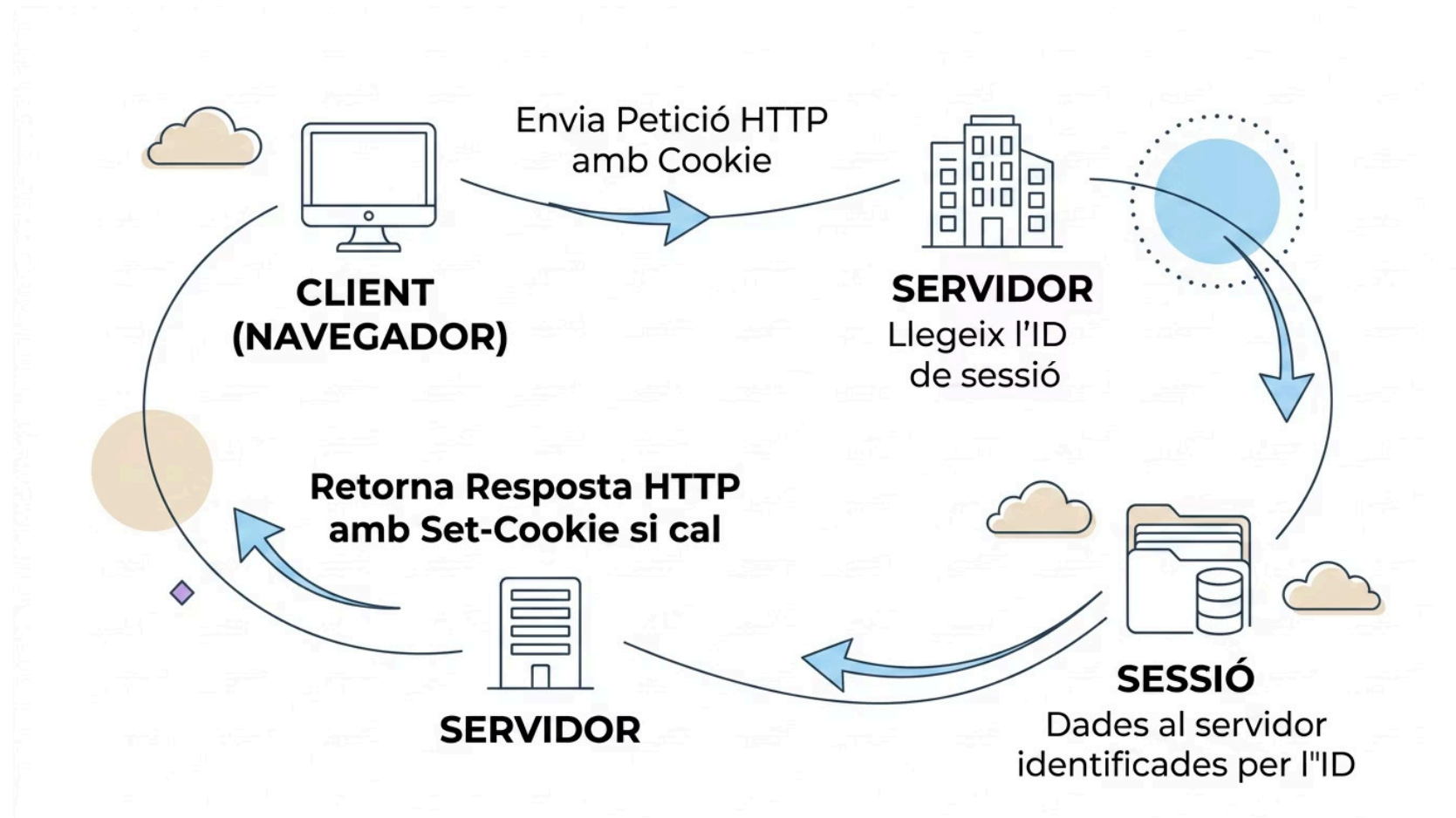


El protocol HTTP és **sense estat** (*stateless*): cada petició és independent i el servidor no recorda les anteriors.

⚠ Sense mecanismes addicionals, no hi ha manera de saber si dues peticions provenen del mateix client.

Per mantenir un **flux coherent** entre peticions (carret de compra, usuari actiu, preferències...) cal afegir estat de manera explícita.

Mapa general: client, cookie, servidor i sessió



 La cookie de sessió només és l'**identificador**. Les dades reals viuen al servidor.

Sessió: dades al servidor

Com funciona

1 `session_start()`

Sempre al principi, abans d'escriure cap sortida HTML.

2 `$_SESSION`

Array superglobal on es guarden les dades associades al client.

3 ID de sessió

PHP genera un identificador únic i l'envia al navegador via cookie.

Exemple PHP

```
// Iniciar sessió
session_start();

// Guardar dada temporal
$_SESSION['usuari_demo'] = 'aina';

// Llegir en una petició posterior
session_start();
$usuari = $_SESSION['usuari_demo'] ?? null;
echo "Hola, $usuari";
```

- ❏ Estat temporal, no persistència de domini. Quan la sessió acaba, les dades desapareixen.

Cookie: dada al client

La cookie és un fragment de dada que el servidor envia al navegador i que **el client reenviarà** en cada petició posterior.

Ús habitual

Identificador de sessió,
preferències d'idioma o tema,
consentiments.

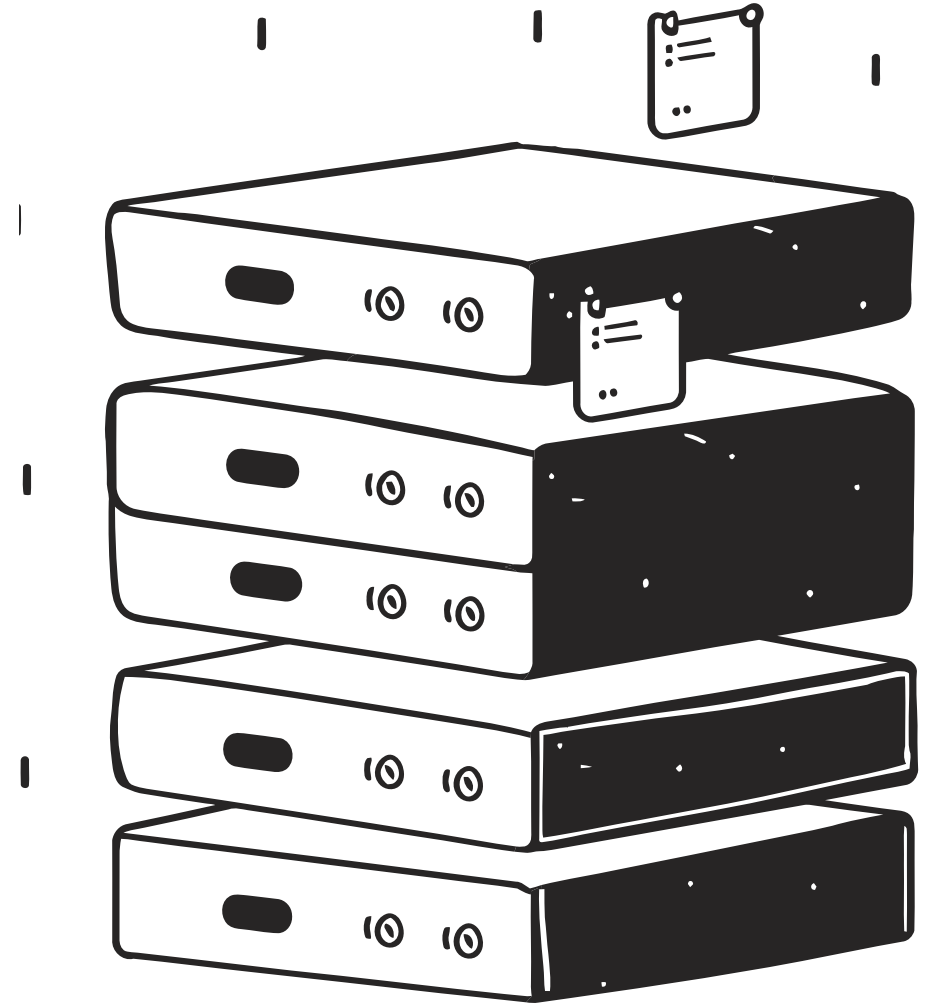
Mai en cookie

Contrasenyes, dades
sensibles o informació que no
ha de llegir el client.

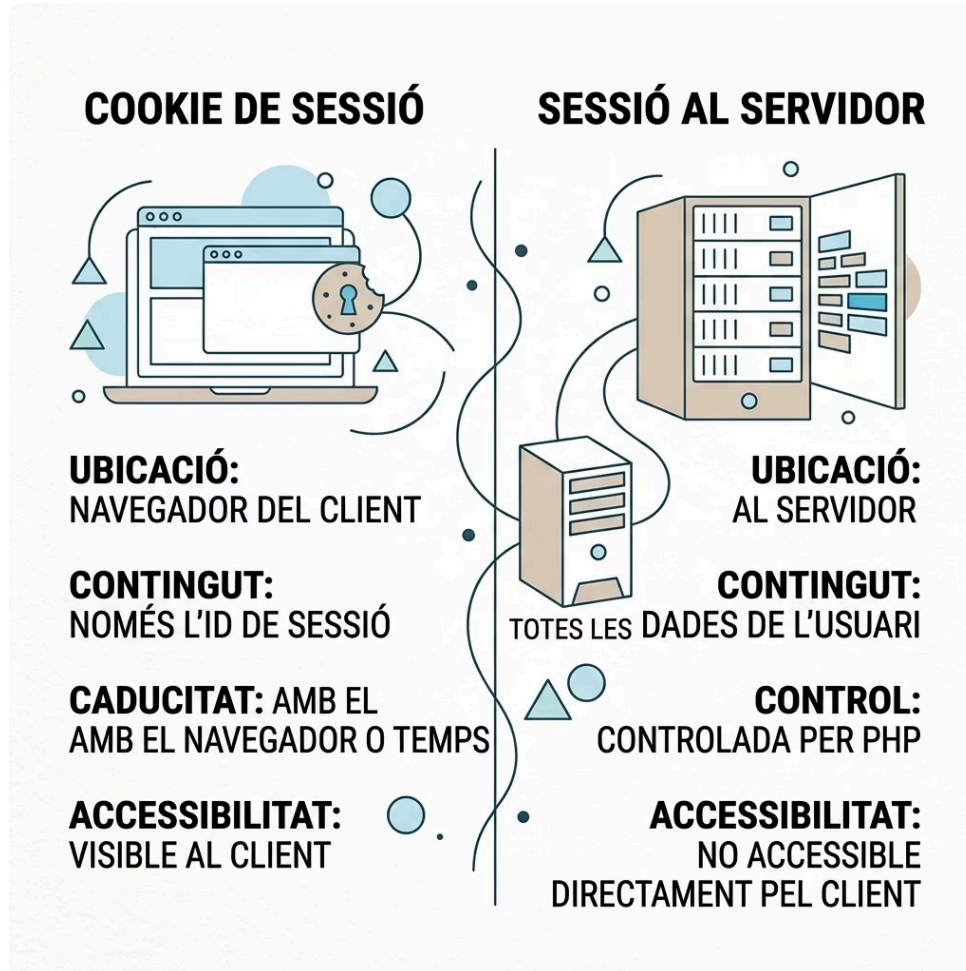
Exemple PHP

```
setcookie('tema', 'clar', time() + 3600, '/');
```

Caducarà en 1 hora. Llegir amb `$_COOKIE['tema']`.



Cookie de sessió ≠ Sessió



Distinció clau

La cookie **apunta** a la sessió; no és la sessió. Si elimines la cookie, perds l'accés a les dades, però les dades continuen al servidor fins que s'invaliden.



Compartir l'ID de sessió és com compartir la clau de casa. Cal protegir-lo i renovar-lo quan canvia l'estat d'autenticació.

Context de petició

PHP exposa informació sobre la petició actual a través de `$_SERVER`. Aporta context, però **no autentica** ningú per si sol.



Mètode HTTP

```
$metode =  
$_SERVER['REQUEST_METHOD'] ??  
'GET';
```

Detecta si la petició és GET, POST, PUT...



Agent del client

`$_SERVER['HTTP_USER_AGENT']` informa del navegador, però es pot falsificar fàcilment.



Adreça IP

`$_SERVER['REMOTE_ADDR']` dóna la IP, però no identifica una persona de manera fiable.

Ruta base i includes estables

El problema

Les rutes relatives en `include` o `require` es calculen respecte al directori de treball, no al fitxer. Si mous un fitxer, les rutes es trenquen.

⊗ Evita: `require '../config.php'` si el fitxer pot canviar de carpeta.

La solució

Defineix una **ruta base absoluta** en un fitxer d'entrada (`config.php` o `bootstrap.php`) i usa-la arreu.

Exemple PHP

```
// config.php o bootstrap.php
define('BASE_PATH', dirname(__DIR__));

// Qualsevol fitxer del projecte
require_once BASE_PATH . '/src/regles.php';
require_once BASE_PATH . '/src/helpers.php';
```

✓ Amb `BASE_PATH` definit una sola vegada, tots els includes funcionen independentment de la carpeta del fitxer que els crida.

Invalidació i neteja de l'estat

L'estat temporal ha de **desaparèixer** quan ja no té sentit. Deixar dades obsoletes pot provocar comportaments inesperats o problemes de seguretat.



Detectar invalidació

Eliminar dades

Redirigir / reiniciar

```
// Eliminar una dada concreta de sessió
```

```
unset($_SESSION['usuari_demo']);
```

```
// Destruir tota la sessió
```

```
session_destroy();
```

```
// Sobreescriure una cookie per caducar-la
```

```
setcookie('tema', '', time() - 1, '/');
```

Errors habituals

session_start() massa tard

Si ja s'ha enviat sortida (HTML, espais, BOM), PHP no pot enviar la capçalera de sessió. Posa `session_start()` sempre al principi.

Dades sensibles en cookie

El client pot llegir i modificar les cookies. Mai guardes contrasenyes, rols o dades crítiques allà.

Confondre context amb autenticació

`$_SERVER['REMOTE_ADDR']` o l'agent del navegador no demostren qui és l'usuari. Són informació de context, no credencials.

Includes amb rutes relatives trencades

Moure un fitxer a una altra carpeta trenca les rutes relatives. Usa sempre `BASE_PATH` com a referència absoluta.



Preguntes de comprovació

Posa a prova els teus coneixements sobre l'estat, les sessions i les cookies amb aquestes preguntes clau:

1

Dades temporals en sessió

Quina dada del teu flux de treball és temporal i es beneficiaria de ser emmagatzemada en una sessió?

2

Dades sensibles i cookies

Quina informació, sota cap concepte, hauria de ser emmagatzemada o enviada a través d'una cookie al client?

3

Cookie vs. Sessió

Explica la diferència fonamental entre una "cookie de sessió" i la "sessió" en si mateixa, incloent on resideix cada una.

4

Utilitat de `$_SERVER`

Quina informació útil proporciona l'array superglobal `$_SERVER` en una petició, i per què no es pot utilitzar per a l'autenticació d'usuaris?

5

Neteja i invalidació

Describeix els mètodes i les millors pràctiques per netejar o invalidar l'estat (sessions i cookies) una vegada que ja no és rellevant o segur mantenir-lo.